

Индивидуальный проект

Этап №5

Сергеев Даниил Олегович

Содержание

1	Цель работы	5
2	Ход выполнения лабораторной работы	6
3	Вывод	13
	Список литературы	14

Список иллюстраций

2.1	Окно BurpSuite	6
2.2	Вкладка Proxu	7
2.3	Перехваченный запрос	7
2.4	Вкладка Target	8
2.5	Перехват POST запроса	8
2.6	Расстановка позиций Intruder	9
2.7	Имена пользователя для перебора	10
2.8	Пароли для перебора	10
2.9	Результат перебора	11
2.10	Информация об ответе	11
2.11	Ответ в Repeater	12
2.12	Предварительный просмотр страницы	12

Список таблиц

1 Цель работы

Целью данной работы является использование приложения BurpSuite в рамках индивидуального проекта. [2]

2 Ход выполнения лабораторной работы

Будем тестировать BurpSuite на основе DVWA, установленного на прошлых этапах. Запустим веб-приложение и BurpSuite.

```
service apache2 start  
service mariadb start
```

Burp Suite представляет собой набор мощных инструментов безопасности веб-приложений, которые демонстрируют реальные возможности злоумышленника, проникающего в веб-приложения. [1]

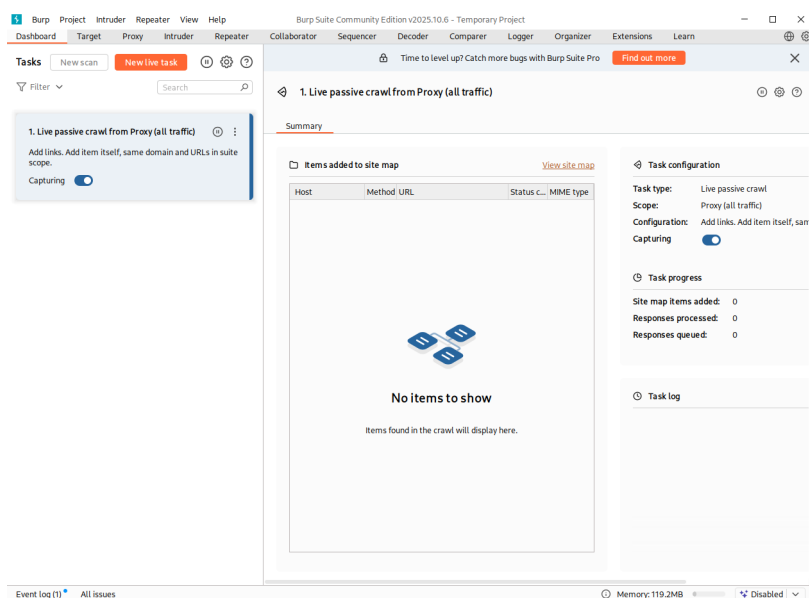


Рисунок 2.1: Окно BurpSuite

Откроем вкладку Proxy и включим перехват запросов (Intercept on) и откроем браузер через приложение (если открыть браузер через BurpSuite, то он автоматически настроит подключение к прокси-серверу). Попробуем посетить целевой сайт localhost/DVWA. Если мы будем просто ждать, то страница не загрузится, из-за того, что BurpSuite перехватил запрос. Откроем Proxy и посмотрим, приложение определило.

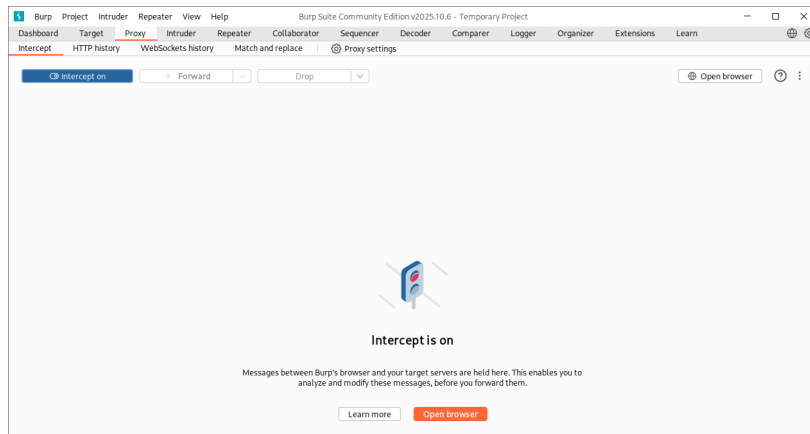


Рисунок 2.2: Вкладка Proxy

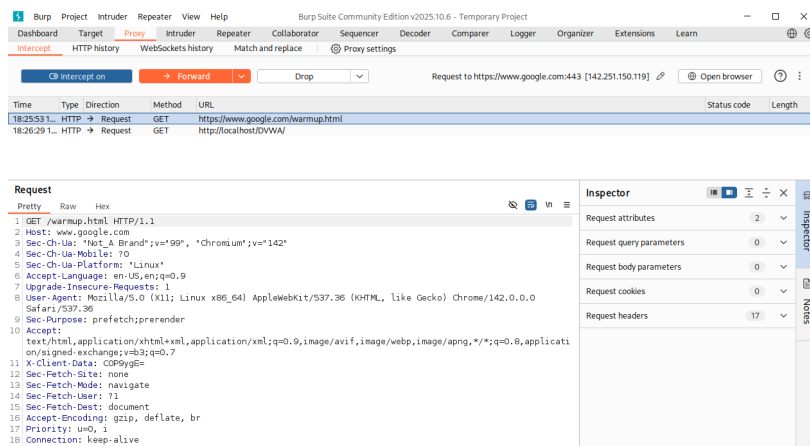


Рисунок 2.3: Перехваченный запрос

После нескольких нажатий на кнопку Forward браузер загрузит веб-страницу, и во вкладке Target появятся некоторые данные. BurpSuite запустит поиск по структуре сайта и определит, в том числе, возможные запросы для страницы.

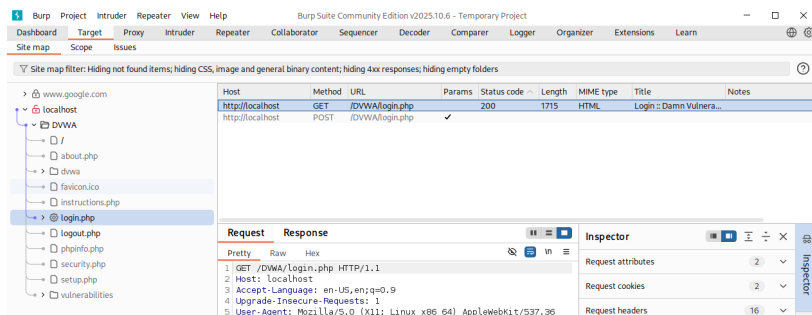


Рисунок 2.4: Вкладка Target

Вернемся на страницу и попробуем сгенерировать трафик, которым воспользуется нарушитель в лице BurpSuite. Заполним в форме входа случайные данные и отправим POST запрос.

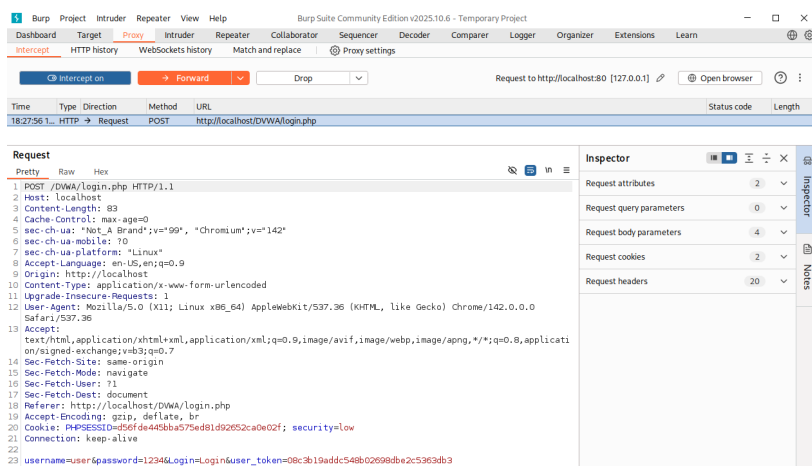


Рисунок 2.5: Перехват POST запроса

Нажмем ПКМ и в появившемся контекстном меню выберем команду Send to Intruder. Внутри вкладки расставим «позиции» в параметрах запроса - user и password.

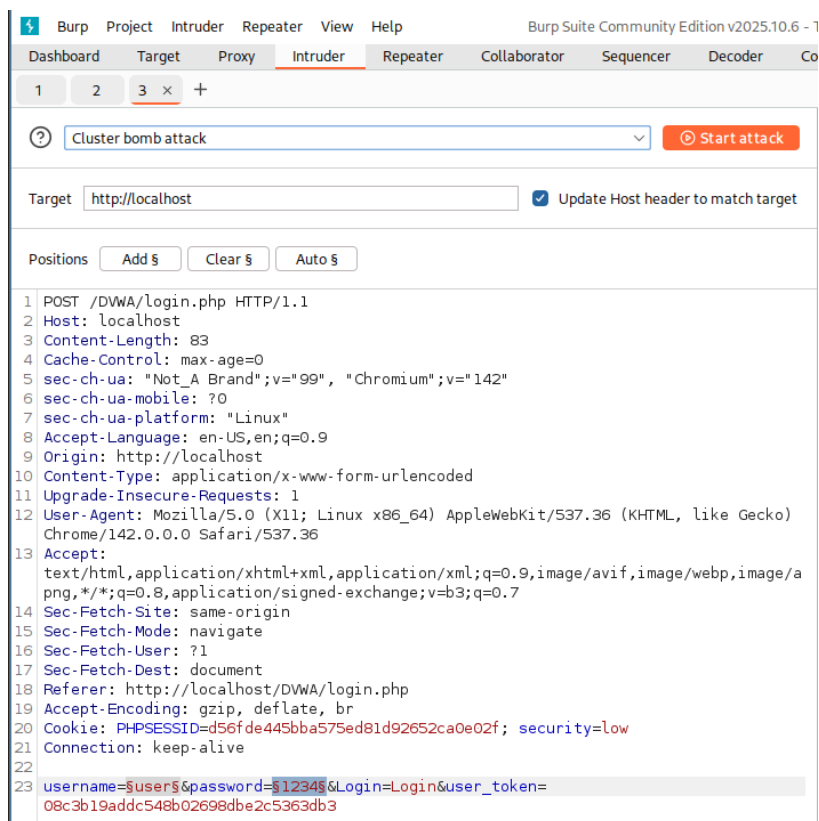


Рисунок 2.6: Расстановка позиций Intruder

Теперь в меню полезных нагрузок Payloads укажем данные для перебора, а именно: имя пользователя (1) и пароль (2).

Payloads

Payload position: 1 - user

Payload type: Simple list

Payload count: 1

Request count: 0

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste admin

Load...

Remove

Clear

Deduplicate

Add

Add from list... [Pro version only]

Рисунок 2.7: Имена пользователя для перебора

Payloads

Payload position: 2 - 1234

Payload type: Simple list

Payload count: 8

Request count: 8

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste 1

Load... 2

Remove 3

Clear 4

Deduplicate pass

password

ilovecats

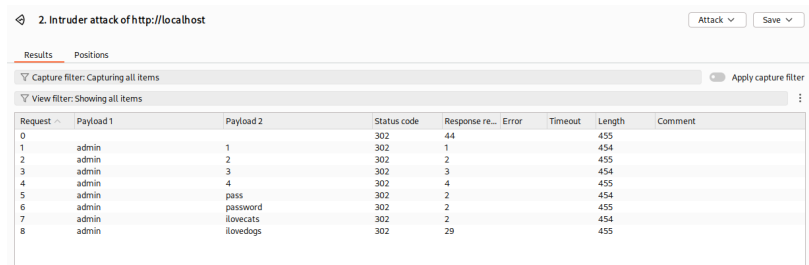
ilovedogs

Add

Add from list... [Pro version only]

Рисунок 2.8: Пароли для перебора

Запустим атаку и посмотрим результаты перебора. Мы можем заметить, что все запросы имеют статус 302 - перенаправление. При неудачной попытке, страница перекидывает нас на форму входа `login.php`, а при удачной - на страницу `index.php`.



Request	Payload 1	Payload 2	Status code	Response re...	Error	Timeout	Length	Comment
0			302	44			455	
1	admin	1	302	1			454	
2	admin	2	302	2			455	
3	admin	3	302	3			454	
4	admin	4	302	4			455	
5	admin	pass	302	2			454	
6	admin	password	302	2			455	
7	admin	ilovecats	302	2			454	
8	admin	ilovedogs	302	29			455	

Рисунок 2.9: Результат перебора



Request	Response
1	HTTP/1.1 302 Found
2	Date: Sat, 16 May 2020 15:31:36 GMT
3	Server: Apache/2.4.18 (Ubuntu)
4	Set-Cookie: PHPSESSID=56fde445bba575ed81d92652ca0e02f; expires=Sun, 17 May 2020 15:31:36 GMT; Max-Age=86400; path=
5	Expires: Thu, 19 Nov 1981 08:52:00 GMT
6	Cache-Control: no-store, no-cache, must-revalidate
7	Pragma: no-cache
8	Location: index.php
9	Content-Length: 0
10	Keep-Alive: timeout=5, max=100
11	Connection: Keep-Alive
12	Content-Type: text/html; charset=UTF-8
13	
14	

Рисунок 2.10: Информация об ответе

Передадим тело POST запроса в Repeater. Здесь мы можем поменять пароль и имя пользователя на правильные и совершить редирект. После этого мы получим ответ в поле Response. Там же мы можем предварительно посмотреть на то, как будет выглядеть страница.

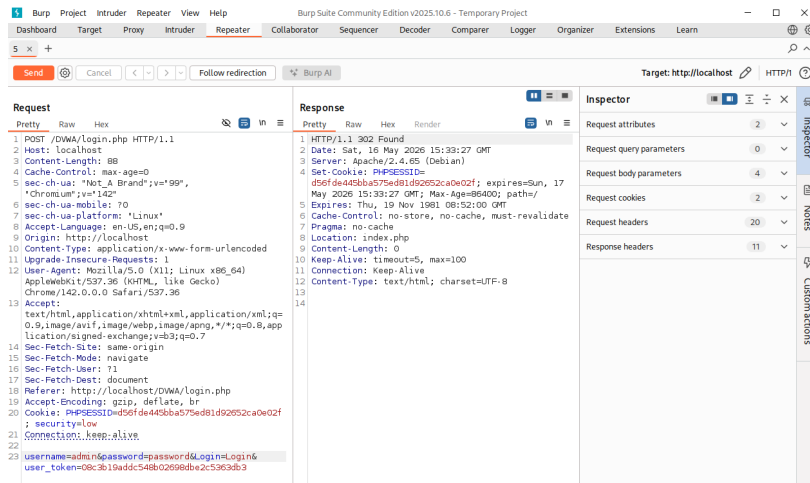


Рисунок 2.11: Ответ в Repeater

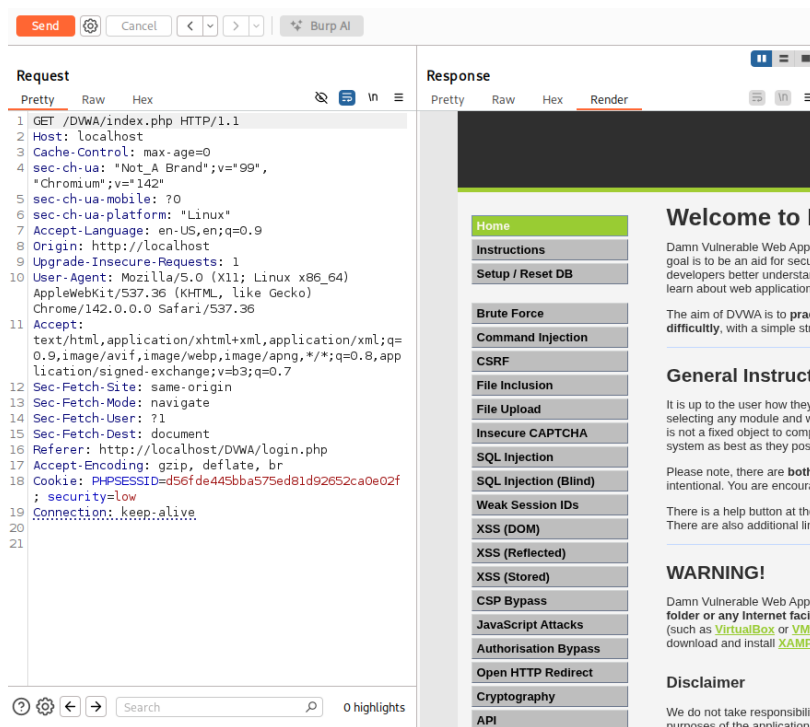


Рисунок 2.12: Предварительный просмотр страницы

3 Вывод

В результате выполнения лабораторной работы я испытал набор инструментов безопасности веб-приложений BurpSuite и узнал как с помощью него можно совершить атаку Cluster bomb на незащищенный сайт.

Список литературы

1. Kali Linux. Тестирование на проникновение и безопасность / Парасрам Ш. [и др.].. — СПб. : Питер, 2020.. — 448 с.
2. Кулябов Д. С., Королькова А. В., Геворкян М. Н. Основы информационной безопасности (09.03.03) : Этапы реализации проекта. — URL: <https://esystem.rudn.ru/mod/page/view.php?id=1357979> (дата обр. 07.03.2026).